FICHE 21 - CHIFFREMENT, HACHAGE, SIGNATURE

Assurer l'intégrité, la confidentialité et l'authenticité d'une information.

Les **fonctions de hachage** permettent d'assurer **l'intégrité des données. Les signatures numériques,** en plus d'assurer l'intégrité, permettent de vérifier l'authenticité de l'identité du signataire et d'assurer la non-répudiation. Enfin, **le chiffrement**[95] permet de garantir **la confidentialité** d'un message.

Les précautions élémentaires

- **Utiliser un algorithme reconnu et sûr,** par exemple, les algorithmes suivants :
  - SHA-2[96] ou SHA-3[97] comme familles de fonctions de hachage ;
  - bcrypt, scrypt, Argon2 ou PBKDF2 pour stocker les mots de passe ;
  - AES[98] avec un mode de construction approprié (CCM, GCM, ou EAX) ou ChaCha20[99] (avec Poly1305) pour le chiffrement symétrique ;
  - RSA-OAEP[100], ECIES-KEM[101] ou DLIES-KEM[101] pour le chiffrement asymétrique ;
  - RSA-SSA-PSS[100] ou ECDSA[102] pour les signatures.
- **Utiliser des tailles de clés suffisantes** :
  - pour AES, les clés de 128, 192 ou 256 bits sont considérées comme suffisantes ;
  - pour les algorithmes basés sur RSA, il est recommandé d'utiliser des modules et exposants secrets d'au moins 2 048 bits ou 3 072 bits, avec des exposants publics, pour le chiffrement, supérieurs à 65 536 bits.
- **Appliquer les recommandations d'utilisation appropriées**, en fonction de l'algorithme utilisé. Les erreurs d'implémentation ont un impact important sur la sécurité du mécanisme cryptographique.
- **Protéger les clés secrètes,** au moins par la mise en œuvre de droits d'accès restrictifs et d'un mot de passe sûr.
- **Rédiger une procédure indiquant la manière dont les clés et certificats vont être gérés** en prenant en compte les cas d'oubli du mot de passe de déverrouillage.

95 Parfois improprement appelé cryptage.

96 Comme défini dans le standard NIST FIPS 180-4.

97 Comme défini dans le NIST FIPS 202.

98 Comme défini dans le NIST FIPS 197.

99 Comme défini dans la RFC 8439.

100 Comme définis dans le standard RSA PKCS#1 v2.2.

101 Comme définis dans la norme ISO/IEC 18033-2.

102 Comme défini dans le NIST FIPS 186-5.